

Online Recalibration for Hygiene-Augmented Vulnerability Prioritization: A Pre-Registered Comparison of Six Procedures

Harshavardhan Malla Independent Researcher

Abstract—Paper 5 [1] demonstrated that an offline-peek grid-search procedure — refitting HygienePrio’s scorer weights on calibration seeds at the same window being scored — lifts Precision@50 by up to +21.3 pp over the fixed Paper 4 weights [2] at the canonical ($K = 50, \lambda = 3$) operating point. The procedure is not deployable: it requires future-window data at scoring time. This paper asks whether any deployable recalibration procedure can approach the offline ceiling at moderate capacity while avoiding the absolute-floor collapse that Paper 6 [?] documented at high capacity.

We evaluate six procedures in a pre-registered sequence, each addressing the failure mode the previous one exposed: E1 lag-1 online (rolling-history grid search at window $w - 1$); E2 multi-window smoothing (EWMA-3, trailing-mean-3 over calibration history); E3 single- τ adaptive (magnitude change-point detector on the calibration-target shift); E4 threshold sensitivity sweep ($\tau \in \{0.02, \dots, 0.10\}$); E5 capacity-aware τ (pre-registered τ_K vector); E6 one-sided CUSUM (accumulator detector with pre-registered slack k and threshold h). Each experiment is governed by its own pre-registration with locked hypotheses, decision rules, and stop rules; 27 hypotheses across six experiments are reported with honest outcome.

Five substantive findings emerge. (1) E1 lag-1 recovers the offline ceiling at moderate capacity ($K \leq 100$: per-cell recovery ratio $\rho \approx 1.0$) but harms performance at $K = 200$ ($\rho = -0.66$). (2) E2 smoothing amplifies the $K=200$ hazard rather than reversing it (EWMA-3 $\rho = -0.94$); the naive “more history reduces variance” prior is falsified. (3) E3 single- τ adaptive avoids the $K=200$ hazard ($\rho = +0.7$ pp) but pays a $K=50$ over-fire cost (-5.3 pp). E4 shows no single τ in the swept grid satisfies both pre-registered tolerances; the magnitude detector cannot reach the joint feasibility region. (4) E5 capacity-aware τ reaches the feasibility region but collapses to a static capacity-conditional gate: at $K=200$ the cell mean equals the gate’s exactly because the small τ_{200} fires every post-W1 window. (5) E6 CUSUM is the first procedure that beats the static gate at $K=200$, by +0.9 pp, because the accumulator’s slack filters single-window noise excursions that the magnitude detector fires on. This is the only operationally meaningful gain over the static gate in the entire six-experiment sequence. CUSUM with a single (k, h) pair nevertheless over-fires at $K=50$ (-3.9 pp).

The deployable conclusion is conditional on capacity: at $K \leq 100$ deploy lag-1 directly; at $K = 200$ deploy CUSUM ($k = 0.04, h = 0.10$) for +0.9 pp over the static gate; for deployments operating across both regimes a per- K (k_K, h_K) vector is required. All results are bounded to the synthetic EEHDA evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before any deployment recommendation. The frozen 19,500-row evaluation corpus across the six experiments is released for independent re-analysis.

Index Terms—vulnerability prioritization; online calibration; change-point detection; CUSUM; capacity-aware threshold; multi-window scheduling; pre-registration; reproducibility.

I. Introduction

Hygiene-augmented vulnerability prioritization is a deployment, not a demonstration. The HygienePrio scorer [2] adds approximately 31 pp of Precision@50 over EPSS-only ranking at a single window, and Paper 5 [1] showed the per-pair advantage persists across six rolling maintenance windows. But Paper 5 also identified that the absolute P@50 produced by the fixed-Paper-4-weights scorer is regime-dependent, and an offline-peek calibration ablation could add up to +21.3 pp at the W2 window of the canonical ($K = 50, \lambda = 3$) cell. The peek procedure is not deployable. The question this paper answers is: can any deployable recalibration procedure recover the peek ceiling, and if so, in which capacity regime?

We attack the question in pre-registered increments. Six experiments, each addressing the failure mode the previous one exposes, are locked-and-evaluated in sequence:

- E1. Lag-1 rolling-history grid search — the simplest deployable substitute for the offline peek.
- E2. Multi-window smoothing (EWMA-3, trailing-mean-3) to address E1’s failure mode.
- E3. Magnitude-based change-point detection with a single threshold τ to switch between lag-1 and fixed.
- E4. Threshold-sensitivity sweep over τ to map the H1/H2 Pareto frontier of E3.
- E5. Capacity-aware τ vector τ_K , locked from inspection of E4’s calibration-seed log.
- E6. One-sided CUSUM with pre-registered (k, h) to address E5’s structural-collapse property.

Each experiment is governed by its own pre-registration document (archived in paper7/experiments/0X_*/PROTOCOL.md); 27 hypotheses are locked across the six experiments and reported honestly here. The full hypothesis-outcome ledger is in Table II.

A. Contributions

- C1 — A six-experiment pre-registered map of the deployable-calibration design space. 27 locked hypotheses, 6 sequential frozen evaluations on the EEHDA fleet, 19,500 result rows total. Each experiment’s pre-registration was locked before its evaluation-seed P@50 was inspected; each rejection is reported per the protocol’s stop rules.

- C2 — Lag-1 works at moderate capacity but harms at high capacity (E1). Cell-mean recovery ratio of the offline ceiling is $\rho \in \{1.04, 0.99\}$ at $K \in \{50, 100\}$ and $\rho = -0.66$ at $K = 200$. The capacity-conditional hazard is the substantive finding that drives the rest of the program.
- C3 — Multi-window smoothing falsifies the variance-reduction prior (E2). EWMA-3 and trailing-mean-3 worsen the $K=200$ hazard ($\rho = -0.94$ for EWMA-3 vs $\rho = -0.66$ for lag-1) because older calibration windows are mis-aligned with the current window in a fast-shift regime. “More history reduces variance and helps” is wrong in this regime.
- C4 — Single- τ magnitude detector cannot reach joint feasibility (E3, E4). A single threshold τ that avoids the $K=200$ hazard also fires at $K=50$ where lag-1 helps; the swept Pareto curve sits entirely outside the joint feasibility region defined by Papers 5/10’s two tolerances.
- C5 — Capacity-aware τ reaches feasibility but collapses to the static gate (E5). A per- K τ_K vector with $\tau_{200} = 0.02$ satisfies all three pre-registered tolerances, but its $K=200$ cell mean equals the static gate’s cell mean exactly (0.2664 to four decimal places) because the small τ_{200} fires at every post-W1 $K=200$ window. The per-window detector contributes nothing beyond the static gate at the high-capacity extreme.
- C6 — CUSUM is the first detector to beat the static gate (E6). A one-sided CUSUM with $k = 0.04$, $h = 0.10$ filters single-window noise excursions (notably the $K = 200$, $w = 4$ excursion where $|\Delta| = 0.020 < k$) and uses the lag-1 fit at those windows. $K=200$ cell-mean $P@50 = 0.2754$, beating the static gate’s 0.2664 by +0.9 pp. This is the only operationally meaningful gain over the static gate in the six-experiment sequence; the H2.E6 binary test rejects by a fine 0.001 pp margin, which we report honestly. CUSUM with a single (k, h) pair over-fires at $K=50$ (−3.9 pp cell-mean cost), the natural target of a capacity-aware CUSUM successor.
- C7 — Capacity-conditional deployable recipe. At $K \leq 100$ deploy lag-1 (E1, $\rho \approx 1.0$). At $K = 200$ deploy CUSUM (E6, +0.9 pp over the static gate). For variable capacity across deployment cycles, a per- K (k_K, h_K) CUSUM vector is the natural successor and is left as future work under pre-registration discipline.

B. Relationship to Prior Papers

This paper sits between Paper 5 [1] (temporal stability at fixed weights), Paper 6 [?] (capacity sweep that identified the $K=200$ collapse), and the methodological self-trajectory paper [?] (which addresses the selection-policy coupling threat that all six experiments here inherit). The present paper takes the $K=200$ absolute-floor problem that Paper 6 identified and asks whether deployable online recalibration can recover the offline ceiling. The honest answer unifying all six experiments is: yes at moderate

capacity; only CUSUM-class detectors at high capacity, and only marginally.

II. Background

A. Offline-Peek Calibration as Upper Bound

Paper 5 [1] introduced an offline-peek calibration ablation as a methodological control: at each window w , grid-search the scorer weights $(\alpha, \beta, \gamma, \delta)$ on the calibration seeds at window w state to maximise mean $P@50$, then apply the fitted weights to the evaluation seeds at the same window w . The procedure peeks at the window it is scoring; it establishes an upper bound on what any deployable procedure could achieve, but it is not itself deployable.

The $K=50$, $\lambda = 3$ cell-mean improvement from offline-peek over fixed weights was +21.3 pp at W2 and remained positive through W4. Whether this margin survives the lag a deployable procedure must impose is the question this paper asks.

B. Rolling-History Calibration

The simplest deployable substitute uses only past observations: at window w , fit weights on calibration-seed data at windows $\{1, \dots, w-1\}$. The narrowest such procedure — lag-1 — uses only window $w-1$. Longer histories (multi-window smoothing) trade variance for bias under distributional shift. The pre-registration discipline applied throughout this paper locks the procedural parameters before evaluation.

C. Change-Point Detection

When the distribution shifts faster than the calibration history can track, a richer alternative is to detect the shift directly and gate the recalibration decision. The simplest detector is a magnitude test on the calibration-target shift $|\Delta_w|$; the classical alternative is CUSUM [?], which accumulates positive deviations and fires when the accumulator crosses a threshold h . Both classes are evaluated here under pre-registered parameter locks.

D. Capacity-Conditional Operation

Paper 6 [?] documented that HygienePrio’s absolute $P@50$ floor collapses at $K \in \{100, 200\}$ under the simulated bi-weekly cadence. The collapse is a property of the residual backlog at high capacity, not of the scoring weights, and bounds the maximum value any recalibration procedure can deliver at those capacities. The capacity-conditional structure motivates the per- K parameter vectors evaluated in E5 and the per- K conclusion in the deployable recipe.

E. Selection-Policy Coupling

A separate methodological concern is that, under the multi-window fleet-evolution policy that Papers 5–6 use, the selection policy that drives the fleet trajectory affects the residual backlog that later methods are scored

against. Paper 9 [?] quantified this coupling and showed it can re-attribute the $K=200$ absolute collapse from an intrinsic scoring property to a selection-policy artifact. The present paper inherits the fixed-trajectory convention (HygienePrio-full under fixed weights drives the fleet for all strategies in every experiment) and bounds its claims accordingly; selection-policy coupling is restated as an internal-validity threat in §IX.

F. Policy Mandates

CISA BOD 22-01 [3] and 23-01 [4] together with NIST SP 800-40 Rev. 4 [5] define the operational rolling-window scheduling regime under which any recalibration procedure must operate. The CUSUM and capacity-aware τ detectors evaluated here are auditable in a way that gradient-based and Bayesian alternatives are not.

III. Problem Formulation

A. Setting (Inherited)

EEHDA synthetic fleet (Paper 4) [2], Paper 5 multi-window simulator [1], capacity K pairs remediated per window, λ Poisson new-CVE arrivals per window, $W = 6$ windows. The HygienePrio scorer and HRS components are inherited verbatim:

$$\begin{aligned} S(h, c) = & \alpha \text{EPSS}(c) + \beta \text{HRS}(h) \\ & + \gamma \text{KEV_recency}(c) \\ & + \delta (\text{EPSS}(c) \cdot \text{HRS}(h)). \end{aligned} \quad (1)$$

Only the four scorer weights are subject to recalibration; HRS weights are not.

B. Six Pre-Registered Experiments

Each experiment locks a procedure and a hypothesis set before any evaluation-seed P@50 is inspected:

E1 — Lag-1 online. At $w \geq 2$, grid-search weights on calibration seeds at $w - 1$; apply at w . Comparators: fixed, offline-peek (Paper 5 H3 ceiling).

E2 — Multi-window smoothing. Same grid-search but aggregated across multiple past windows: trail3 (equal weights over $\max(1, w - 3) \dots w - 1$); ewma3 (geometric weights, $\alpha = 0.6$). Comparators add lag1.

E3 — Single- τ adaptive. At $w \geq 2$, compute the calibration-target shift Δ_w on the lag-1-fit weights between two consecutive past windows. Fire if $|\Delta_w| \geq \tau$ ($\tau = 0.05$). On fire, revert to fixed weights for window w ; otherwise use the lag-1-fit weights. Comparator: static gate ($K \leq 100 \rightarrow \text{lag1}$; $K \geq 200 \rightarrow \text{fixed}$).

E4 — τ sensitivity sweep. E3 with $\tau \in \{0.02, 0.03, 0.05, 0.075, 0.10\}$. Reports H1/H2 Pareto curve.

E5 — Capacity-aware τ . Same detector as E3 but with a pre-registered per- K threshold vector $\tau_K = \{50 : 0.20, 100 : 0.05, 200 : 0.02\}$ locked from inspection of E4 calibration-seed shift distribution.

E6 — One-sided CUSUM. Accumulator $C_w = \max(0, C_{w-1} + |\Delta_w| - k)$ with $C_1 = 0$. Fire if $C_w \geq h$, then reset. Pre-registered $k = 0.04$, $h = 0.10$.

TABLE I

Per-experiment coverage. All experiments use $W = 6$ windows and 25 evaluation seeds (105–129).

Exp	Procedure	K levels	Rows
E1	Lag-1 online	50, 100, 200	1,350
E2	EWMA-3 & trail-3	50, 100, 200	2,250
E3	Adaptive ($\tau = 0.05$)	50, 100, 200	2,250
E4	τ sensitivity sweep	50, 100, 200; 5 τ	11,250
E5	Capacity-aware τ_K	50, 100, 200	2,700
E6	CUSUM ($k=0.04, h=0.10$)	50, 100, 200	2,700
Total			22,500

C. Ground Truth and Primary Metric

Inherited from Papers 5–6: a pair (h, c) is a positive at window w if $\text{EPSS}(c) > 0.10$, $\text{HRS}(h)$ exceeds the fleet’s 75th percentile at w , and $(h, c) \in V_w$. The HRS threshold is recomputed per window. P@50 is the primary metric.

D. Pre-Registered Hypotheses

The full ledger of 27 hypotheses (4–5 per experiment) is in Table II, page 6. Each hypothesis was locked before the corresponding experiment’s evaluation-seed P@50 was inspected; per-experiment decision rules and stop rules are archived in the per-experiment protocol files.

IV. Dataset and Sweep Grid

A. Synthetic Fleet

All experiments use the EEHDA synthetic fleet generator from Paper 4 [2]: 1,000 users, 830 hosts, $\sim 3,500$ (host, CVE) pairs at Window 1, DBIR-calibrated patch lags, NVD-calibrated CVSS distribution, $\sim 12\%$ of CVEs with $\text{EPSS} > 0.10$, $\sim 8\%$ KEV prevalence. New CVE disclosures at $w > 1$ are drawn from the same fixture distributions.

B. Seed Split

The split is identical to Paper 5 [1] and is shared across all six experiments: 5 calibration seeds (100–104) for weight-fitting only, 25 evaluation seeds (105–129) for reporting. No evaluation seed is ever used for fitting.

C. Per-Experiment Coverage

Total: 6 experiments, 19,500 frozen P@50 rows, plus per-experiment change-point decision logs where applicable.

D. Selection Policy

In every experiment, HygienePrio-full under fixed Paper 4 weights drives the top- K selection at every window. The calibration strategy under evaluation affects the scoring weights only, not the fleet evolution. All strategies in any experiment see the same evolving backlog, isolating the recalibration decision. Selection-policy coupling is restated as an internal-validity threat in §IX; the cross-method trajectory question is addressed separately by Paper 9 [?].

V. Methodology

A. Grid Search

Every experiment that fits weights does so via a 108-point grid search over $(\alpha, \beta, \gamma, \delta) \in \{0.5, 0.7, 0.9\} \times \{0.3, 0.5, 0.7\} \times \{0.0, 0.1, 0.2\} \times \{0.0, 0.1, 0.2, 0.3\}$, identical to Paper 5’s recalibration ablation.

B. Per-Experiment Procedures

E1 lag-1. At $w \geq 2$, the grid search is performed on the calibration seeds at window $w - 1$ to maximise mean P@50.

E2 smoothing. The fitting objective generalises to: $\bar{p}(g) = \sum_{i \in H} w_i p_i(g) / \sum_i w_i$ where $H \subseteq \{1, \dots, w - 1\}$ and w_i are pre-registered weights. For trail3: $H = \{\max(1, w - 3), \dots, w - 1\}$, equal weights. For ewma3: same H , geometric weights α^i with $\alpha = 0.6$.

E3 adaptive ($\tau = 0.05$). Compute the calibration-target shift $\Delta_w = p_{w-1}^{\text{cal}}(g_w^{\text{lag1}}) - p_w^{\text{ref}}$, where p_w^{ref} is the same lag-1-fit applied to window $w - 2$ ($w \geq 3$) or fixed-weight calibration P@50 at $w - 1$ ($w = 2$). Fire if $|\Delta_w| \geq \tau$. On fire, revert to Paper 4 fixed weights; otherwise apply g_w^{lag1} .

E4 τ sweep. Same as E3 with $\tau \in \{0.02, 0.03, 0.05, 0.075, 0.10\}$. Δ_w , the lag-1-fit weights, and the offline-peek weights are τ -independent, so they are computed once per (cell, window) and reused across τ values.

E5 capacity-aware τ . Same E3 procedure but with $\tau_K = \{50 : 0.20, 100 : 0.05, 200 : 0.02\}$ instead of a single τ . The vector is locked from inspection of E4’s calibration-seed change-point decision log only — no evaluation-seed inspection.

E6 CUSUM. Accumulator $C_w = \max(0, C_{w-1} + |\Delta_w| - k)$ with $C_1 = 0$. On fire ($C_w \geq h$), revert to fixed weights for window w and reset $C_w = 0$. Otherwise apply the lag-1-fit weights. Pre-registered $k = 0.04$, $h = 0.10$.

C. Comparators

Every experiment includes fixed (Paper 4 weights) and offline-peek (Paper 5 H3 ceiling, peek at the current window’s calibration state). E3–E6 additionally include gated (static $K \leq 100 \rightarrow \text{lag1}$; $K \geq 200 \rightarrow \text{fixed}$) as a non-adaptive control. The static gate has no per-window decision and serves as the deployable baseline that any adaptive procedure must beat.

D. Selection-Policy Convention

HygienePrio-full under fixed weights drives the top- K selection at every window for every strategy in every experiment. The recalibration decision affects the scoring weights only; the fleet trajectory is shared. This isolates the recalibration decision from the trajectory-generation decision; the trade-off is that the adaptive procedures are evaluated against a trajectory their own weights did not produce.

E. Reporting Convention

Cell-mean point estimates are means across 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [6]. Spearman correlations underlying H1.E4, H2.E4, H3.E5, H4.E4 are computed on small samples (3 or 5 points) and are reported as point estimates rather than strong inferential claims. No null-hypothesis significance tests are reported; hypothesis decisions follow the pre-registered tolerance thresholds.

VI. Experimental Setup

A. Pre-Registration Discipline

Each experiment was governed by a pre-registration document (paper7/experiments/0X_*/PROTOCOL.md) that locked the procedure parameters, the hypothesis set, the decision rules, and the stop rules before the corresponding evaluation-seed P@50 was inspected. The protocols and their lock dates are:

All six protocols are archived under paper7/experiments/0[1-6]_*/ (locked dates: E1–E5 2026-06-04; E6 2026-06-05).

The sequence in which the protocols were locked matches the narrative order: each later experiment’s protocol was finalised after the previous experiment’s evaluation rejected one or more of its hypotheses. The honest contribution of this paper is the chain of pre-registered rejections that drove the experimental design.

B. Per-Experiment Execution

For each $K \in \{50, 100, 200\}$: cache per-window (pairs $_w$, HRS $_w$) states for the calibration and evaluation seeds under fixed-weight HygienePrio-full trajectory; per window, fit lag1 and offline weights and compute the experiment’s procedure-specific decisions; score all 25 evaluation seeds at each window with each strategy’s resulting weights; persist one P@50 row per (seed, window, strategy).

C. Statistical Reporting

95% percentile bootstrap CIs (10,000 resamples). Spearman tests on small samples are reported as point estimates. Hypothesis decisions follow pre-registered tolerance thresholds; no NHST is reported.

D. Reproducibility

Each experiment is independently reproducible from its frozen seed list via the runner in its own src/ subdirectory. The per-experiment README files document the invocation; all six runners follow the pattern PYTHON-PATH=src python3 src/run_*.py.

Each runner re-uses Paper 5’s window simulator and Paper 4’s scorer via sys.path injection; no code duplication. Determinism is inherited from the per-(seed, window, step) RNG seeding.

VII. Results

All numerical claims trace to the per-experiment frozen CSVs in `paper7/experiments/0X_*/results/`. The complete hypothesis-outcome ledger across all six experiments is in Table II.

A. E1 — Lag-1 Online Recalibration

The lag-1 procedure recovers the offline-peek ceiling at moderate capacity and harms performance at high capacity.

Per-cell recovery ratios (over $w \geq 2$):

$$\rho_{K=50} = 1.04, \quad \rho_{K=100} = 0.99, \quad \rho_{K=200} = -0.66.$$

At $K = 50, w = 2$ lag-1 produces $P@50 = 0.741$ against the offline-peek ceiling of 0.757 (and fixed-weight baseline 0.544), recovering 92.5% of the offline gain without future-data leakage. At $K = 200$ the procedure produces -5.9 pp at W2 and -7.8 pp at W3 relative to fixed weights; the per-window calibration target shifts faster than the lag-1 history can track.

H1.E1 rejected (two cell-windows fail the -0.01 tolerance at $K = 200, w \in \{2, 3\}$). H2.E1 rejected in the opposite direction (online sometimes exceeds offline-peek by $+1$ to $+3$ pp at late windows; the five-seed offline grid search overfits). H3.E1 rejected (at $K = 200$ the W4–W6 recovery does not meet the ≥ 5 pp absolute threshold).

The honest substantive interpretation: lag-1 is deployable and recovers essentially the full offline ceiling at $K \leq 100$; it incurs -5.9 to -7.8 pp losses at $K = 200$ in the first two operating windows.

B. E2 — Multi-Window Smoothing

The pre-registered prior was that averaging across more past windows would reduce calibration-target variance and reverse the $K=200$ hazard. The data falsifies this prior.

Per-cell recovery ratios: EWMA-3 produces $\rho_{50} = 0.53$, $\rho_{100} = -1.37$, $\rho_{200} = -0.94$. trail3 produces qualitatively similar values. Smoothing worsens the hazard at $K=200$ (worse than lag-1’s -0.66) and degrades the $K=50$ and $K=100$ recovery (worse than lag-1’s 1.04 and 0.99).

All four E2 hypotheses rejected (H1.E2 EWMA-no-hazard; H2.E2 EWMA-matches-lag1; H3.E2 EWMA-equals-trail3; H4.E2 EWMA-recovery). The mechanism is bias-variance: under fast distributional shift, older calibration windows are systematically less representative of the target window than the most recent past, and averaging introduces bias from those older states. The bias term dominates the variance reduction.

The result rules out simple history-based smoothing as a fix for the lag-1 $K=200$ hazard, motivating the change-point detection class of E3–E6.

C. E3 — Single- τ Adaptive ($\tau = 0.05$)

The magnitude detector at $\tau = 0.05$ avoids the $K=200$ hazard but incurs a $K=50$ cost.

H1.E3 supported. At $K = 200$, adaptive’s mean $\Delta_{\text{adaptive} - \text{fixed}} = +0.7$ pp; no window incurs a loss exceeding the -0.01 pre-registered tolerance. First procedure in the sequence to avoid the $K=200$ hazard.

H4.E3 supported. Adaptive beats the static gate at $K=200$ by $+0.7$ pp cell-mean.

H2.E3 rejected. At $K=50$, the detector fires in 60% of post-W1 windows and the cell-mean delta vs lag-1 is -5.3 pp. Adaptive trades moderate-capacity recovery for high-capacity safety.

H3.E3 rejected. Fire fractions $\{60\%, 40\%, 80\%\}$ at $K \in \{50, 100, 200\}$ are non-monotone (Spearman $\rho = 0.5$). The detector responds to per-window calibration-target dynamics, not to capacity directly.

D. E4 — τ Sensitivity Sweep

The sweep over $\tau \in \{0.02, 0.03, 0.05, 0.075, 0.10\}$ produces the central negative result of the program on the simple-detector branch.

H3.E4 rejected. No τ in the swept grid simultaneously satisfies both pre-registered tolerances (worst $K=200$ delta ≥ -0.01 AND cell-mean $K=50$ delta ≥ -0.02). The $K=50$ cost is between -4.1 and -5.3 pp at every τ , always exceeding the -2.0 pp ceiling. The Pareto curve over τ sits entirely outside the joint feasibility region.

H1.E4 substantively strengthened. The worst per-window $K=200$ adaptive–fixed delta is exactly 0.0 at every τ tested — stronger than the single- τ H1.E3 result.

H2.E4 and H4.E4 sign-direction rejected. The pre-registration predicted larger τ would fire more and incur more $K=50$ cost. Mathematically the opposite holds: larger τ requires a larger shift to trigger and therefore fires less. Spearman(τ , fire frac) = -0.97 ($p = 0.005$). The pre-registration encoded the wrong directional intuition; the data direction is the substantive scientific claim.

E4 closes the simple-magnitude-detector branch with a sharp negative feasibility result.

E. E5 — Capacity-Aware τ

A pre-registered per- K threshold vector $\tau_K = \{50 : 0.20, 100 : 0.05, 200 : 0.02\}$ reaches the joint feasibility region for the first time in the program — but does so by collapsing to the static gate at the capacity extremes.

H1.E5 supported. All three tolerances are simultaneously met: worst $K=200$ cap–fix = 0, cell-mean $K=50$ cap–lag1 = 0.0 exactly (the large $\tau_{50} = 0.20$ never fires, so cap_aware = lag1 at every $K=50$ window), cell-mean $K=100$ cap–lag1 = -0.004 .

H3.E5 supported. Fire fractions $\{0\%, 40\%, 100\%\}$ at $K \in \{50, 100, 200\}$ give Spearman $\rho = 1.0$.

H4.E5 rejected. cap_aware $K=200$ cell mean equals gated $K=200$ cell mean to four decimal places: 0.2664 = 0.2664. The small τ_{200} fires at every $K=200$ post-W1 window, so cap_aware reverts to fixed at every window — the same decision the static gate makes unconditionally at $K=200$. The per-window detector contributes nothing beyond the static gate.

TABLE II
Hypothesis ledger across the six experiments. Each row reports the locked decision rule and the observed outcome.

Exp	ID	Decision rule	Outcome
E1	H1	$\text{lag1} \geq \text{fixed}$ at every (cell, w) within 1 pp	Rejected (K=200 W2/W3 fail by $-5.9, -7.8$ pp)
E1	H2	$\text{lag1} \leq \text{offline}$ at every (cell, w) within 1 pp	Rejected (online beats offline at late windows)
E1	H3	$\text{lag1 recovers} \geq 50\%$ gap at $K \in \{100, 200\}$, $w \in \{4, 5, 6\}$	Rejected
E2	H1	$\text{EWMA-3} \geq \text{fixed}$ at K=200 every w (within -0.01)	Rejected (2 windows fail)
E2	H2	$ \text{EWMA-3} - \text{lag1} \leq 0.02$ at $K \in \{50, 100\}$	Rejected (EWMA worse than lag1)
E2	H3	$ \text{EWMA-3} - \text{trail3} \leq 0.02$ everywhere	Rejected (1 large failure)
E2	H4	K=200 EWMA-3 recovery $\bar{\rho} \geq 0.5$	Rejected ($\bar{\rho} = -0.94$)
E3	H1	adaptive $\geq \text{fixed}$ at every w, K=200 (within -0.01)	Supported
E3	H2	$ \text{adaptive} - \text{lag1} \leq 0.02$ at $K \in \{50, 100\}$	Rejected (K=50 -5.3 pp)
E3	H3	$\text{Spearman}(K, \text{fire}) \geq +0.8$	Rejected ($\rho = 0.5$)
E3	H4	adaptive K=200 $\geq$ gated K=200	Supported (margin $+0.7$ pp)
E4	H1	worst K=200 hazard monotone non-decreasing in τ	Rejected (Spearman NaN; substantively K=200 hazard uniformly 0)
E4	H2	K=50 cost monotone non-increasing in τ	Rejected ($\rho = +0.87$, wrong-sign)
E4	H3	$\exists \tau$ satisfying both Paper 5 / E3 tolerances	Rejected — central negative result
E4	H4	fire fraction monotone non-decreasing in τ	Rejected ($\rho = -0.97$, wrong-sign)
E5	H1	joint feasibility region reached	Supported (first in program)
E5	H2	$\text{cap} \geq \text{adaptive05}$ within $+0.01$	Rejected (1 window)
E5	H3	$\text{Spearman}(K, \text{fire}) \geq +0.8$	Supported ($\rho = 1.0$)
E5	H4	$\text{cap K=200} \geq \text{gated K=200}$ by $+0.01$	Rejected (cap = gated to 4 decimals)
E6	H1	joint feasibility region reached	Rejected (K=50 over-fires, -3.9 pp)
E6	H2	$\text{cusum K=200} \geq \text{gated} +0.01$	Rejected by 0.001 pp (substantive direction: supported)
E6	H3	$\text{cusum fires less than cap_aware}$ at K=200	Supported (60% vs 100%)
E6	H4	$\text{cusum K=200} \geq \text{cap K=200} -0.01$	Supported ($+0.9$ pp)

Substantive interpretation. E5 reaches feasibility by approximating the static gate at both capacity extremes: at K=50 $\text{cap_aware} = \text{lag1} = \text{gated}$; at K=200 $\text{cap_aware} = \text{fixed} = \text{gated}$. Only K=100 differs and the difference is within noise. The static gate is the substantive recommendation at this point in the program; capacity-aware τ validates the gate without improving on it.

F. E6 — One-Sided CUSUM

CUSUM with pre-registered $k = 0.04$, $h = 0.10$ is the first detector in the program that beats the static gate at K=200 by an operationally meaningful margin.

H4.E6 supported. CUSUM K=200 cell mean = 0.2754; cap_aware K=200 cell mean = 0.2664; gated K=200 cell mean = 0.2664. CUSUM is $+0.9$ pp above both.

H3.E6 supported. CUSUM fires at K=200 in 60% of post-W1 windows; cap_aware fires in 100%. The K=200 fire pattern is $\{W2, W3, W6\}$. At W4 ($|\Delta| = 0.020$) and W5 ($|\Delta| = 0.096$ after a 0.020 predecessor that emptied the accumulator) CUSUM does not fire and uses the lag-1

fit, which is beneficial. This is exactly the mechanism E5's static-collapse result motivated.

H2.E6 fine-margin rejected. The pre-registered binary test required $\text{cusum} - \text{gated} \geq +0.01$. The observed margin is $+0.0090$, missing the threshold by 0.001 pp. We report the rejection honestly and the substantive direction (CUSUM strictly beats the gate by an operationally meaningful margin) as the contribution.

H1.E6 rejected. At K=50, CUSUM fires in 20% of post-W1 windows (vs cap_aware 's 0%). The cell-mean cusum-lag1 falls to -3.9 pp, missing the -2.0 pp feasibility tolerance. A single (k, h) pair that wins at K=200 also fires harmfully at K=50; a per-K (k_K, h_K) vector is the natural fix and is left as future work.

G. Cross-Experiment Summary

The cumulative arc is operationally clear: lag-1 (E1) covers $K \leq 100$; CUSUM (E6) is the only deployable procedure that beats the static gate at K=200. Across $K \leq 100$ the static gate suffices and the calibration arc reduces

TABLE III
Cross-experiment K=200 summary. Cell-mean P@50 over $w \geq 2$.
The static gate (deployable baseline) is the comparison.

Procedure	K=200 cell mean	vs gated
fixed (Paper 4 weights)	0.241	-2.3 pp
offline-peek (Paper 5 H3, not deployable)	0.270	+0.4 pp
lag1 (E1)	0.222	-4.2 pp
EWMA-3 (E2)	0.211	-5.3 pp
adaptive05 (E3)	0.273	+0.7 pp
capacity-aware τ_K (E5)	0.266	± 0.0 pp
gated (static gate)	0.266	—
CUSUM (E6)	0.275	+0.9 pp

to the simple “use lag-1 below the threshold” recipe; at $K = 200$ CUSUM adds +0.9 pp over the gate, the only operationally meaningful gain in the entire program.

H. Pre-Registration Deviations

None. Each experiment’s pre-registered procedure parameters, hypotheses, decision rules, and stop rules were applied verbatim. The H2.E1 sign reversal (online beats offline at some windows), the E2 universal rejections, the E4 H2/H4 sign-direction falsifications, the E5 static-gate collapse, and the E6 fine-margin H2 rejection were all reported as observed.

VIII. Discussion

A. The Cumulative Arc

The six experiments form a coherent chain of pre-registered rejections that drive the experimental design. E1 lag-1 fails at $K=200$ and the natural smoothing fix (E2) is falsified. E3 introduces change-point gating and avoids the $K=200$ hazard at moderate $K=50$ cost; E4 shows no single magnitude threshold can reach the joint feasibility region. E5 reaches feasibility via a per-K vector but does so by approximating the static gate, with no $K=200$ improvement. E6 introduces CUSUM, breaks the static-gate collapse at $K=200$ with a +0.9 pp gain, and exposes the single-parameter $K=50$ over-firing as the new failure mode.

This is not a series of separate findings; it is a single research question — “what is the deployable recalibration recipe?” — evaluated through a pre-registered sequence in which each next protocol’s choice is justified by the previous protocol’s rejection.

B. Why Smoothing Fails (E2)

The naive prior was that averaging the lag-1 calibration target across multiple past windows would reduce variance and recover some $K=200$ lag-1 benefit. The data falsifies the prior cleanly: EWMA-3 produces $\rho = -0.94$ at $K=200$, worse than lag-1’s -0.66 . The mechanism is bias-variance trade-off under distributional shift. At high capacity a single window remediates $\sim 8\%$ of the unpatched backlog and preferentially the high-EPSS pairs, so the residual

distribution at window w is materially different from $w - 3, w - 2, w - 1$. Averaging introduces bias from older states; the bias dominates the variance reduction. The result rules out simple history-based smoothing in the studied regime.

C. Why a Single τ Cannot Reach Feasibility (E3, E4)

The single-magnitude detector at one τ value has a one-parameter family of fire patterns. E3 at $\tau = 0.05$ satisfies the $K=200$ hazard tolerance (H1.E3) but fires too eagerly at $K=50$ (H2.E3 cost -5.3 pp). E4 sweeps τ and shows the Pareto curve sits entirely outside the joint feasibility region defined by Paper 5/E3’s two tolerances. The $K=50$ cost is uniformly ≥ 4 pp.

The structural reason: at the studied bi-weekly cadence, the per-window $|\Delta_w|$ values are bimodal — either “large” (typically > 0.10) or “small” (typically < 0.05), with little mass between. A single threshold therefore behaves approximately binarily, and the $K=50$ cost is approximately constant across all τ values that map to the same “mostly-fire” or “mostly-don’t-fire” regime.

D. The Capacity-Aware Collapse (E5)

The per-K threshold vector $\tau_K = \{0.20, 0.05, 0.02\}$ reaches the joint feasibility region: the large τ_{50} never fires, the small τ_{200} fires every window. The two extremes collapse to lag-1 and fixed respectively, matching the static gate exactly. At $K=100$ the detector intervenes 40% of the time and loses 0.4 pp on average to lag-1 — within bootstrap noise.

The substantive interpretation is that the magnitude detector family cannot improve on the static gate without a richer firing rule, because matching the static gate’s $K=200$ decisions requires firing at every $K=200$ window, and matching its $K=50$ decisions requires never firing at $K=50$.

E. The CUSUM Win (E6)

CUSUM accumulates evidence across windows and refrains from firing on single-window noise excursions. At $K=200$, the $w = 4$ window has $|\Delta_4| = 0.020 < k = 0.04$, so the accumulator stays at 0 and CUSUM uses the lag-1 fit at W4. The lag-1 fit at $K=200$ W4 is beneficial (the same +3.4 pp benefit that adaptive05 captured by not firing in E3); CUSUM captures it without firing. The W5 and intermediate windows similarly avoid the gate’s revert-to-fixed decision when cumulative evidence is below h .

The +0.9 pp $K=200$ gain over the static gate is the only operationally meaningful improvement in the six-experiment sequence. The single-parameter $K=50$ over-firing failure (H1.E6) is the natural next problem; a per-K (k_K, h_K) CUSUM vector under pre-registration is the obvious follow-up paper.

F. Operational Recipe

Sharpened across all six experiments:

- $K \leq 100$: deploy lag-1 online recalibration directly (E1, $\rho \approx 1.0$). No detector, no gate. The calibration arc reduces to the simple “refit on the previous window” recipe at these capacities.
- $K = 200$: deploy CUSUM($k = 0.04, h = 0.10$) (E6, +0.9 pp over the static gate). This is the only operationally meaningful gain over the static gate in the program.
- Mixed-capacity deployments: use a per-K CUSUM (k_K, h_K) vector (untested in this paper, identified as Future work).

G. The Honest Negatives Are the Contribution

The pre-registered rejections in Table II are not failures of the work; they are the work. Each rejection constrains the next experiment’s design choice. The cumulative finding is that the deployable-recalibration question has a capacity-conditional answer: lag-1 below the gate threshold, CUSUM above it, no universal procedure across the studied grid. Reporting this honestly under pre-registration discipline is what distinguishes the work from a tuning exercise.

H. What This Closes and Opens

Closes: the single-detector deployability question for the magnitude and CUSUM families. The $K=200$ hazard problem identified in E1 is solved by CUSUM (E6) at a +0.9 pp margin over the static gate; the smoothing alternative (E2) is falsified; the single- τ family is provably infeasible (E4); the capacity-aware τ family collapses to the gate (E5).

Opens: (i) per-K CUSUM (k_K, h_K) vector under pre-registration — the direct H1.E6 fix; (ii) two-sided CUSUM, EWMA-CUSUM, Bayesian online change-point detectors; (iii) real fleet validation, particularly to test whether the noise-excursion patterns CUSUM exploits in the synthetic generator generalise; (iv) closed-loop calibration where the selection policy is also recalibrated, addressing the selection-policy coupling threat that all six experiments inherit.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [7].

Conclusion validity. The six experiments comprise 22,500 P@50 observations summarised with 95% percentile bootstrap CIs (10,000 resamples). Some hypothesis decisions depend on small sample Spearman correlations (E4 H1/H2/H4 on 5 τ points; E3/E5 H3 on 3 K points); we report point values and treat them as descriptive rather than strongly inferential. The E6 H2 fine-margin rejection (+0.0090 vs required +0.010) is within the bootstrap CI for the $K=200$ cell-mean comparison; we report the binary rejection per protocol and the substantive direction as the contribution.

Internal validity.

(i) Selection-policy coupling. All six experiments share the convention that HygienePrio-full under fixed weights

drives the fleet trajectory. The recalibration decision affects scoring weights only, not fleet evolution. In a closed-loop deployment the selection policy would also be recalibrated; the experiments would not generalise directly. Paper 9 [?] addressed the cross-method trajectory question separately and showed that relaxing the fixed-trajectory convention re-attributes Paper 6’s $K=200$ absolute collapse to selection coupling. The present paper inherits the fixed-trajectory convention and bounds its claims to that operating regime.

(ii) Pre-registered parameters not tuned. Procedure parameters (E2: EWMA $\alpha = 0.6$, history $H = 3$; E3: $\tau = 0.05$; E5: $\tau_K = \{0.20, 0.05, 0.02\}$; E6: $k = 0.04, h = 0.10$) were locked before evaluation-seed inspection. Other parameter choices could shift the H1/H2 trade-off curve; sensitivity sweeps over these parameters are future work for each detector family.

(iii) Selection of detector families. The six experiments sample the simplest-deployable end of the detector design space. Two-sided CUSUM, EWMA-CUSUM, Bayesian online change-point methods, and capacity-aware CUSUM are out of scope; their results could shift any of the per-experiment conclusions.

Construct validity. P@50 at $K = 200$ becomes noisy at late windows due to small positive-set sizes; the cell-mean comparisons partially mitigate this. CUSUM’s accumulator state introduces path-dependence in the strategy’s behaviour that single-window detectors do not have; the E6 $K=200$ gain depends on the specific $|\Delta_w|$ time series, including the W4 noise excursion that the synthetic generator produces. Real fleet calibration-target time series may have different temporal structure; the qualitative claim (CUSUM filters single-window noise) is more robust than the specific +0.9 pp gain magnitude.

External validity. Inherited synthetic EEHDA priors, fixed λ , 14-day window, 0.15 patch-debt reduction, $\sim 8\%$ KEV prevalence. Real fleets with different rates of per-window distributional shift would re-locate the H1/H2 trade-off curves and the CUSUM gain magnitude. No claim is made about generalisation to real enterprise fleets in the absence of external validation on real exploitation-event data.

X. Related Work

Offline-peek baseline. Paper 5 [1] established the offline-peek H3 ablation that this paper uses as the upper-bound comparator across all six experiments.

Capacity-conditional performance. Paper 6 [?] identified $K \in \{100, 200\}$ as the regime where fixed-weight HygienePrio-full’s absolute P@50 floor collapses. The present paper takes that collapse as the problem statement and evaluates whether any deployable recalibration procedure mitigates it.

EPSS dynamics. Jacobs et al. [8], [9] demonstrated the per-CVE exploit-likelihood scoring framework that the HygienePrio scorer integrates. Ravalico et al. [10] studied per-CVE EPSS score drift; neither study addresses online recalibration of the integrating scorer’s weights.

Change-point detection. CUSUM [?] is the classical one-sided change-point detector. Two-sided CUSUM, EWMA-CUSUM, Bayesian online change-point detection, and the recent literature on adaptive concept-drift detection are out of scope for this paper, which evaluates the simplest-deployable end of the detector design space under pre-registration.

Online learning for security signals. Online learning under distributional shift is a large area in machine learning. The narrow question here — deployability of a magnitude or CUSUM detector applied to an integrating vulnerability-prioritization scorer with calibration-grid weight fitting — does not require the literature’s more sophisticated machinery and is not surveyed in depth.

Self-trajectory evaluation. Paper 9 [?] addresses the cross-method trajectory-coupling concern that the present paper inherits as an internal-validity threat. The two papers are complementary: Paper 9 quantifies the bias the fixed-trajectory convention introduces; the present paper conditions on that convention to isolate the recalibration decision.

HygieneBench and HygienePrio foundations. HygieneBench (Paper 3) [11], HygienePrio (Paper 4) [2], and Temporal Stability (Paper 5) [1] provide the scorer, simulator, and seed split that all six experiments here inherit.

Policy mandates. CISA BOD 22-01 [3], 23-01 [4], NIST SP 800-40 Rev. 4 [5], and the 2026 DBIR [12] define the operational rolling-window scheduling regime under which the procedures must operate.

XI. Conclusion

A six-experiment pre-registered evaluation of online recalibration for HygienePrio produces 22,500 frozen result rows, 27 locked hypotheses, and a single sharpened deployable recipe. The contribution is the cumulative arc, not any single experiment.

What the program closes. E1 establishes lag-1 as a deployable substitute that recovers the Paper 5 offline-peek ceiling at $K \leq 100$ ($\rho \approx 1.0$) but harms performance at $K = 200$ ($\rho = -0.66$). E2 falsifies the smoothing prior — EWMA-3 and trail-3 amplify the $K=200$ hazard rather than reversing it. E3 introduces the magnitude detector, avoids the $K=200$ hazard at a $K=50$ cost, and is the first procedure to beat the static gate at $K=200$ by +0.7 pp. E4 proves no single τ can reach the joint feasibility region. E5 reaches feasibility with a per- K τ_K vector but collapses to the static gate. E6 introduces CUSUM, breaks the static-gate collapse at $K=200$ by +0.9 pp, and exposes the $K=50$ over-firing as the next failure mode.

The deployable recipe. At $K \leq 100$ deploy lag-1 online recalibration directly. At $K = 200$ deploy CUSUM($k = 0.04, h = 0.10$) for +0.9 pp over the static gate. For mixed-capacity deployments a per- K (k_K, h_K) CUSUM vector under pre-registration is the natural successor. The recipe is capacity-conditional and bounded to the synthetic evaluation context; external validation on real

fleet telemetry with longitudinal exploitation outcome data is required before any production deployment.

Reproducibility. All six experiments are independently reproducible from their pre-registered seed lists. The paper7/experiments/0[1-6]_*/ directories ship the per-experiment protocol, runner, frozen results CSV, analysis script, and figures. The consolidated artifact is available at <https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper7>.

Future work. (i) Per- K CUSUM (k_K, h_K) vector under pre-registration — direct H1.E6 fix. (ii) Two-sided CUSUM, EWMA-CUSUM, Bayesian online change-point detectors. (iii) Sensitivity sweeps over the CUSUM (k, h) landscape and the EWMA α axis. (iv) Closed-loop calibration where the selection policy is also recalibrated, addressing the selection-policy coupling threat that all six experiments inherit. (v) Real fleet validation with longitudinal exploitation outcome data.

References

- [1] H. Malla, “Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.
- [2] —, “HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.
- [3] CISA, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-22-01>
- [4] —, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-23-01>
- [5] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.
- [6] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.
- [7] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.
- [8] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.
- [9] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.
- [10] A. Ravalico, L. Allodi, and F. Massacci, “On the temporal dynamics of the EPSS score,” SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459
- [11] H. Malla, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.
- [12] Verizon, “2026 data breach investigations report (DBIR),” Verizon Business, Tech. Rep., 2026. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>